

Introducción

Este informe documenta la identificación y explotación de una vulnerabilidad de Inyección SQL (SQL Injection) en la aplicación Damn Vulnerable Web Application (DVWA), configurada dentro de un entorno virtual controlado basado en Debian con Apache, MariaDB y PHP (LAMP). El objetivo de la práctica fue demostrar cómo una aplicación vulnerable puede permitir acceso no autorizado a información almacenada en bases de datos debido a una validación insuficiente de entradas.

Descripción del Incidente

Durante la evaluación de seguridad realizada sobre DVWA, se identificó una vulnerabilidad en el módulo “SQL Injection” mientras el nivel de seguridad estaba configurado en “Low”.

La aplicación aceptó datos ingresados por el usuario sin aplicar mecanismos adecuados de validación o sanitización, permitiendo modificar la consulta SQL original ejecutada contra la base de datos.

Como consecuencia, fue posible recuperar información adicional distinta a la solicitada inicialmente.

Entorno Utilizado

El laboratorio fue configurado con los siguientes componentes:

- * Máquina virtual Debian
- * Servidor web Apache
- * Base de datos MariaDB
- * Entorno PHP
- * DVWA (Damn Vulnerable Web Application)
- * Nivel de seguridad configurado en: Low

Método de Inyección SQL Utilizado

Para demostrar la vulnerabilidad se introdujo el siguiente payload en el campo “User ID”:

sql

1' OR '1'='1

Este payload modifica la lógica de la consulta SQL introduciendo una condición que siempre resulta verdadera.

Comportamiento normal:

Entrada:

1

Resultado:

La aplicación devuelve información asociada únicamente a un usuario.

Entrada manipulada:

1' OR '1'='1

Resultado:

La consulta devuelve múltiples registros almacenados en la base de datos, permitiendo acceder a información adicional sin autorización.

Impacto del Incidente

La explotación exitosa de esta vulnerabilidad podría permitir a un atacante:

- Acceder a información confidencial almacenada en la base de datos
- Enumerar usuarios existentes dentro del sistema
- Obtener datos sin autorización
- Facilitar ataques posteriores contra mecanismos de autenticación
- Comprometer la confidencialidad e integridad de la información

La presencia de esta vulnerabilidad representa un riesgo significativo para la seguridad de aplicaciones web que manejan información sensible.

Evidencias Observadas Durante la Prueba

Los siguientes resultados confirmaron la explotación exitosa:

- * La consulta con entrada normal devolvió un único registro
- * La consulta manipulada devolvió múltiples registros
- * La aplicación aceptó instrucciones SQL inyectadas por el usuario
- * Fue posible obtener información adicional sin autenticación adicional

Recomendaciones

1. Uso de Consultas Preparadas (Prepared Statements)

Implementar consultas parametrizadas para evitar concatenar directamente entradas del usuario con instrucciones SQL.

2. Validación y Sanitización de Entradas

Aplicar controles estrictos sobre toda información ingresada por usuarios antes de procesarla.

3. Principio de Mínimos Privilegios

Configurar cuentas de base de datos con únicamente los permisos necesarios para reducir impacto ante compromisos.

4. Auditorías y Pruebas de Seguridad

Realizar evaluaciones periódicas de seguridad y pruebas de penetración para detectar vulnerabilidades antes de su explotación.

5. Capacitación en Desarrollo Seguro

Formar al personal técnico sobre prácticas seguras de programación y vulnerabilidades comunes como SQL Injection.

Conclusiones

La identificación y explotación exitosa de una vulnerabilidad SQL Injection en DVWA demuestra la importancia de implementar controles adecuados de validación de entradas y desarrollo seguro de aplicaciones.

Aunque el entorno utilizado fue diseñado con fines educativos, vulnerabilidades similares en sistemas reales pueden provocar exposición de datos sensibles, accesos no autorizados y compromisos importantes de seguridad.

Este laboratorio permitió comprender el funcionamiento práctico de SQL Injection y reforzó la importancia de aplicar medidas preventivas para proteger aplicaciones web y bases de datos.